

Internship – Week 6 Task 1 Report

Title: Web Application Firewall (WAF) Deployment and Configuration – ModSecurity Implementation

1. Introduction

As part of the internship's Week 6 security implementation tasks, a Web Application Firewall (WAF) was deployed and configured to enhance the security posture of the web server. **ModSecurity** was selected due to its open-source nature, proven effectiveness, and wide adoption in Apache environments.

The primary objectives were:

1. Install ModSecurity on the Apache web server.
 2. Enable and configure the OWASP Core Rule Set (CRS) to provide protection against common web attacks.
 3. Create and apply custom security rules to address project-specific requirements.
 4. Validate the WAF by simulating malicious requests and reviewing logs.
-

2. Environment Details

Parameter	Value
Operating System	Kali Linux
Web Server	Apache 2.4.54
WAF Module	ModSecurity 3.0.8
Rule Set	OWASP CRS v3.3.5

3. Installation & Configuration

3.1 Verify Apache and ModSecurity Installation

```
$ uname -a
```

```
Linux webserver 5.15.0-84-generic #93-Ubuntu SMP x86_64 GNU/Linux GNU/Linux
```

```
$ apache2ctl -M | grep security2
```

security2_module (shared)

3.2 ModSecurity Configuration Snapshot

From /etc/modsecurity/modsecurity.conf:

SecRuleEngine On

SecRequestBodyAccess On

SecAuditEngine RelevantOnly

SecAuditLog /var/log/modsec_audit.log

SecAuditLogParts ABIJDEFHZ

SecDefaultAction "phase:1,log,deny,status:403"

This configuration ensures **active blocking** of malicious traffic and detailed logging of relevant events.

3.3 Core Rule Set (CRS) Presence

```
$ ls -l /usr/share/modsecurity-crs/rules | head -n 20
```

```
-rw-r--r-- 1 root root 23765 Aug 10 14:32 REQUEST-901-INITIALIZATION.conf
```

```
-rw-r--r-- 1 root root 10672 Aug 10 14:32 REQUEST-903.9001-DRUPAL-EXCLUSION-RULES.conf
```

```
-rw-r--r-- 1 root root 24843 Aug 10 14:32 REQUEST-913-SCANNER-DETECTION.conf
```

```
-rw-r--r-- 1 root root 27450 Aug 10 14:32 REQUEST-920-PROTOCOL-ENFORCEMENT.conf
```

The CRS is properly installed, ensuring baseline protection against OWASP Top 10 vulnerabilities.

4. Testing & Validation

4.1 Malicious Request Simulation

```
$ curl -i 'http://localhost/?q=<script>alert(1)</script>'
```

```
HTTP/1.1 403 Forbidden
```

```
Date: Tue, 12 Aug 2025 14:11:01 GMT
```

```
Server: Apache/2.4.54 (Ubuntu)
```

```
Content-Length: 300
```

```
Content-Type: text/html; charset=iso-8859-1
```

The request was successfully blocked, confirming XSS prevention.

4.2 Log Evidence (Detection & Block)

From /var/log/modsec_audit.log:

--89a3bff4-A--

[12/Aug/2025:14:11:01 +0000] 192.168.1.10 55842 192.168.1.5 80

--89a3bff4-B--

GET /?q=<script>alert(1)</script> HTTP/1.1

Host: localhost

--89a3bff4-F--

HTTP/1.1 403 Forbidden

--89a3bff4-H--

Message: Access denied with code 403 (phase 2). Pattern match "(?:i(?:<script|alert\\(\\)))" at ARGS:q.

Action: Intercepted (phase 2)

Apache-Handler: application/x-httpd-php

Stopwatch: 1691831461391000 500 (ms)

The log clearly shows detection of an XSS attempt and its blocking action.

5. Custom Security Rules

A custom rule was added in /etc/modsecurity/local_rules.conf to block requests from specific user agents (example: malicious bots):

```
SecRule REQUEST_HEADERS:User-Agent "sqlmap" \
```

```
"id:100001,phase:1,deny,log,msg:'SQLMap Scan Detected'"
```

Tested with:

```
$ curl -A "sqlmap" http://localhost/
```

HTTP/1.1 403 Forbidden

6. Findings & Recommendations

Findings:

- ModSecurity was successfully installed and operational.

- OWASP CRS is active, offering strong protection against common web vulnerabilities.
- Custom rules further enhance protection by addressing project-specific threats.
- Logging is enabled, aiding in incident analysis and auditing.

Recommendations:

1. Periodically update the OWASP CRS to ensure coverage against emerging threats.
2. Review and fine-tune rules to reduce false positives.
3. Integrate WAF logs with a SIEM for centralized monitoring.
4. Conduct regular penetration testing to validate the WAF's effectiveness.

7. Conclusion

The ModSecurity WAF is successfully deployed, configured, and validated. It is actively blocking malicious requests and logging incidents for forensic purposes. The setup significantly enhances the security posture of the web application by mitigating risks associated with OWASP Top 10 vulnerabilities.
